

گزارش تکمیل فاز ۶

نقش‌ها، مجوزها، کنترل‌های چرخه عمر و ردپای ممیزی

۸۴

تست موفق

0

خطای Django check

۳

نقش عملیاتی

وضعیت نهایی: پیاده‌سازی و آزمون فاز ۶ با موفقیت تکمیل شد

تهیه شده در ۲۹ ژوئیه ۲۰۲۶ | نسخه داخلی پروژه

۱. خلاصه اجرایی

فاز ۶ بر کنترل دسترسی، جلوگیری از دور زدن منطق کسب و کار و ثبت رویدادهای ممیزی متمرکز است.

آینده هیچ کدام منطق مجوزدهی یا تغییر چرخه عمر خودرو را تکرار نکنند. عملیات حساس اکنون از سرویس های مرکزی عبور می کنند. این فاز یک لایه مشترک برای احراز صلاحیت کارکنان ایجاد می کند تا Django Admin، وبسایت، ربات تلگرام و Workerهای

می شوند، دلیل و انجام دهنده ثبت می شود، و فقط مدیر اصلی می تواند خودرو را بازگرداند. بازگردانی همیشه خودرو را به Draft می برد. تغییر مهم این فاز، تکمیل بایگانی نرم خودرو است: خودروهای Draft و For Sale بدون حذف فیزیکی بایگانی

خروجی های تأیید شده

کنترل	نتیجه	وضعیت
کل Test Suite	۸۴ تست با موفقیت اجرا شد	تأیید شده
Django check	بدون خطا System check	تأیید شده
Migration consistency	No changes detected	تأیید شده
sync_roles	همگام شدند Employee و Clearance Employee	تأیید شده

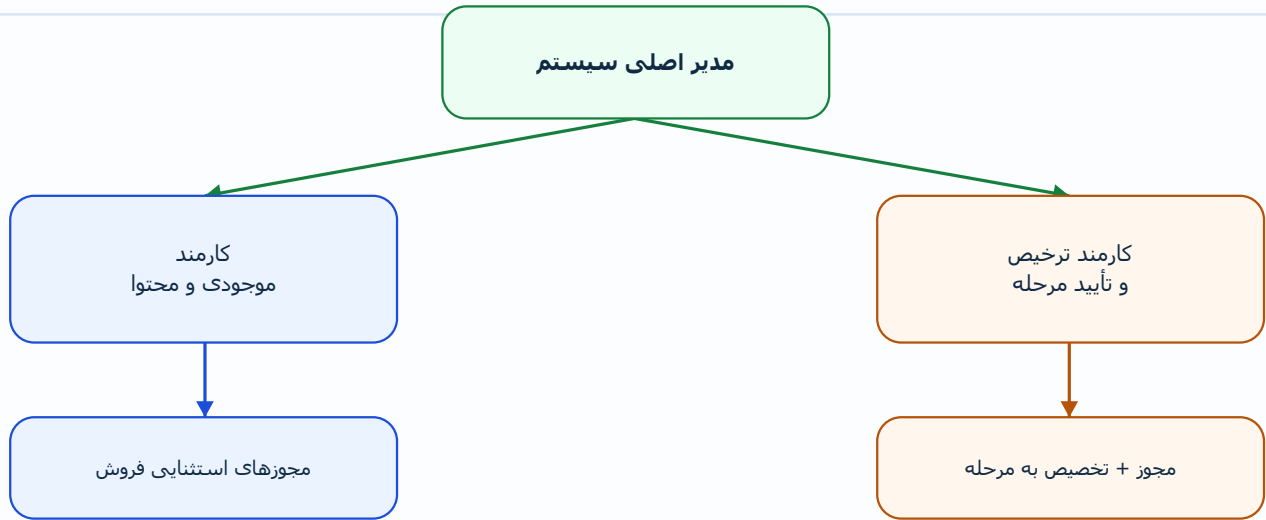
مرز فاز ۶

- پیاده سازی نقش ها، مجوزها، تخصیص Stage و امنیت Django Admin انجام شده است.
- ربات تلگرام، انتشار در کانال، Worker، Excel Import، های تجاری و ظاهر AdminLTE جزو این فاز نیستند.
- هر رابط آینده باید فقط Adapter باشد و برای عملیات کسب و کار Service مشترک را فراخوانی کند.

۲. معماری نقش‌ها و مجوزها

سه نقش عملیاتی با Django Group و یک نقش مدیریتی با is_superuser پیاده‌سازی شده‌اند.

نمودار ۲ - مدل نقش‌ها و دسترسی‌ها



مدیر اصلی با is_superuser پیاده‌سازی شده و گروه تکراری برای او ساخته نشده است.

نقش کسب‌وکار	نمای فنی	محدوده دسترسی
مدیر اصلی سیستم	is_superuser=True	بازگردانی خودرو، مدیریت نقش‌ها و Stageها، دسترسی کامل،
کارمند	Group: Employee	عملیات حساس فقط با مجوز مستقل موجودی، محتوا، مشاهده درخواست‌ها؛
کارمند ترخیص	Group + StaffProfile.assigned_stages	Stageهای تخصیص‌یافته و مجوز Import آینده تأیید
مشتری	بدون نقش داخلی	با کد غیرقابل‌حذف؛ پنل ورود در این فاز ندارد رهگیری عمومی

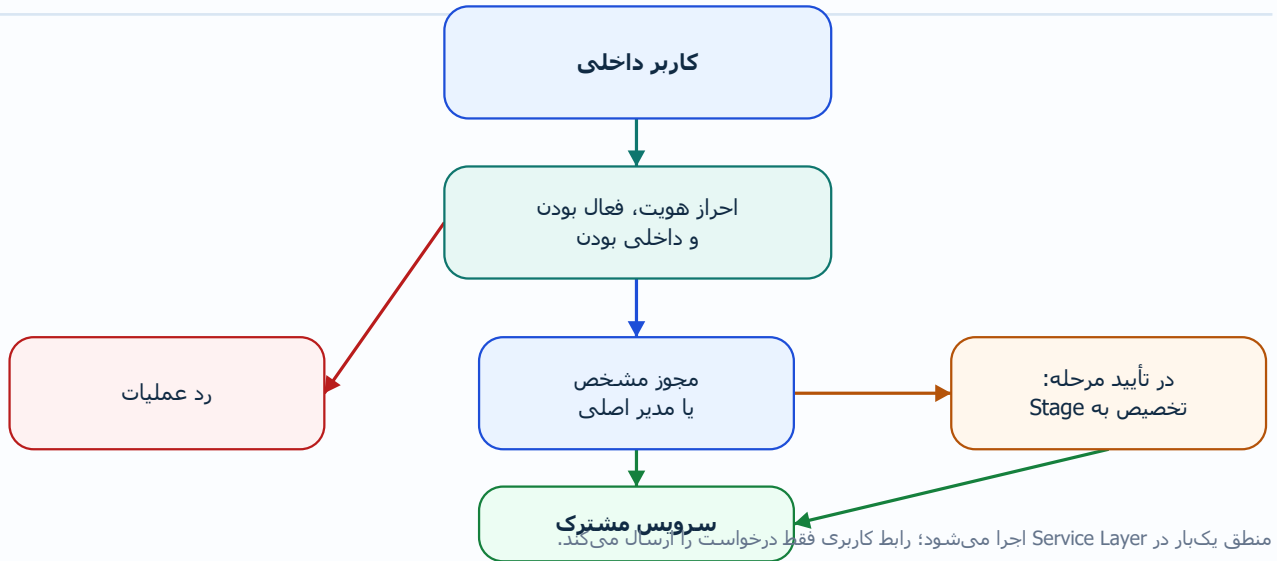
اصل مهم

Stage و بایگانی Stage به همه کارکنان داده نمی‌شود. مدیر اصلی آنها را فقط برای افراد مجاز به صورت صریح اختصاص می‌دهد. مجوزهای فروش، آزادسازی رزرو، تبدیل درخواست به فروش، اصلاح/پرش

۳. مجوزدهی متمرکز و DRY

کنترل‌ها در `accounts/authorization.py` قرار گرفته‌اند و وابسته به View یا Admin نیستند.

نمودار ۱ - دروازه متمرکز مجوزدهی

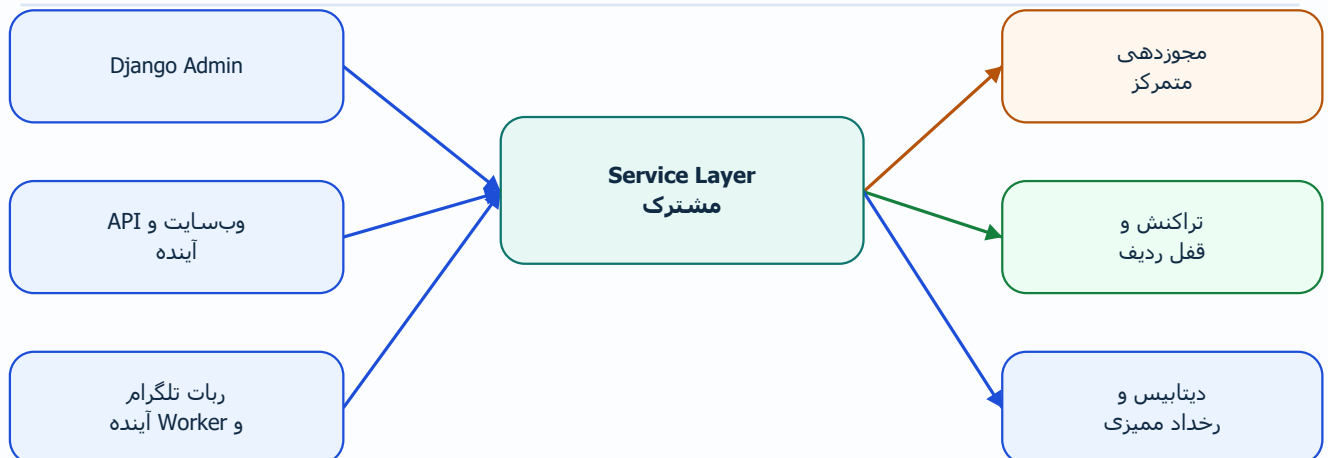


• `require_active_internal_staff`: ورود، فعال بودن حساب و داخلی بودن کاربر را بررسی می‌کند.

• `require_permission`: دارد bypass، صریح را بررسی می‌کند؛ مدیر اصلی پس از عبور از کنترل فعال/داخلی Django permission یک مجاز.

• `require_stage_confirmation_permission`: را نیز بررسی می‌کند Stage تخصیص کارمند به همان Stage، علاوه بر مجوز تأیید.

نمودار ۲ - مرز DRY و Service Layer مشترک



همه رابط‌ها باید سرویس یکسان را فراخوانی کنند؛ تغییر مستقیم فیلد چرخه عمر مجاز نیست.

۴. پوشش Service Layer مشترک

عملیات حساس از سرویس استفاده می‌کنند؛ Admin فقط یک Adapter امن است.

دامنه	سرویس‌های محافظت‌شده	مجوز/کنترل
موجودی	انتشار خودرو برای فروش	publish_vehicle
چرخه فروش	رزرو موقت، آزادسازی و ثبت فروش	hold_vehicle / release_vehicle_hold / sell_vehicle
موجودی	بایگانی نرم و بازگردانی خودرو	مدیر اصلی + archive_vehicle
مشتریان	تبدیل درخواست سفارشی به فروش	convert_custom_vehicle_request _to_sale + sell_vehicle
رهگیری	تأیید و تکمیل مرحله	confirm_tracking_stage + Stage assignment
رهگیری	کنترل‌های استثنایی مراحل	skip / correct / archive tracking stage

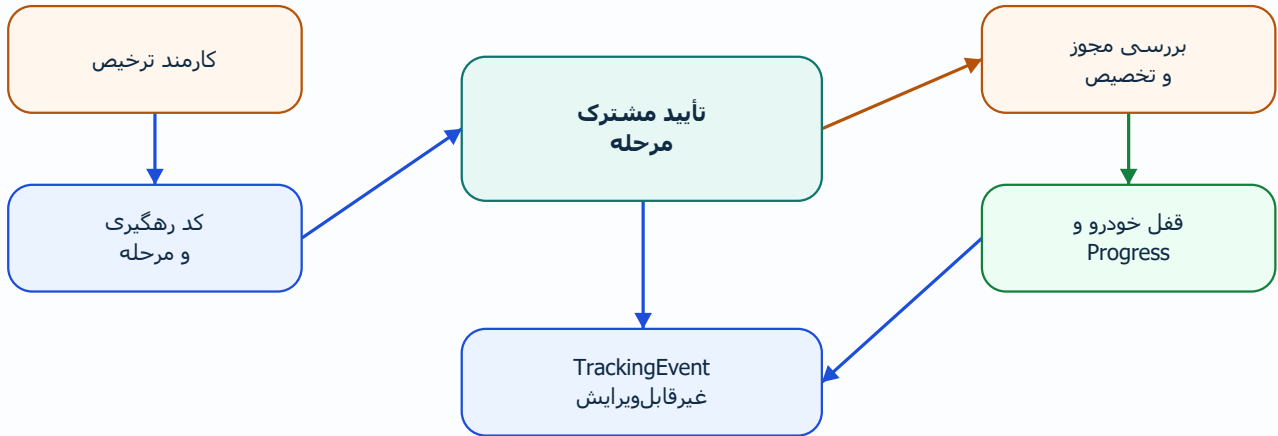
نتیجه معماری

آن‌ها فقط ورودی معتبر را جمع‌آوری و سرویس مشترک را فراخوانی می‌کنند؛ بنابراین DRY در سطح Business Logic حفظ می‌شود. وب‌سایت و ربات تلگرام در آینده نباید نسخه دیگری از منطق فروش، تأیید Stage یا بایگانی خودرو داشته باشند.

۵. کنترل‌های رهگیری و تأیید Stage

مجوز عمومی به‌تنهایی برای تأیید یک مرحله کافی نیست؛ کارمند باید به همان Stage تخصیص داشته باشد.

نمودار ۴ - جریان تأیید مرحله رهگیری



کارمند عادی فقط برای Stage‌های تخصیص‌یافته و فقط با مجوز صریح اجازه تأیید دارد.

کنترل پیاده‌سازی‌شده	هدف	ریسک مهارشده
StaffProfile.assigned_stages	تعیین Stage‌های هر کارمند	مرحله توسط فرد نامرتبط تأیید
TrackingEvent غیرقابل ویرایش	ثبت تاریخچه ورود، تکمیل، پرش و اصلاح	از بین رفتن ردپای تصمیم
و تراکنش select_for_update	قفل رکورد خودرو و Progress	و ناسازگاری وضعیت تأیید هم‌زمان
Admin readonly برای Progress	جلوگیری از تغییر مستقیم وضعیت	دور زدن Service Layer

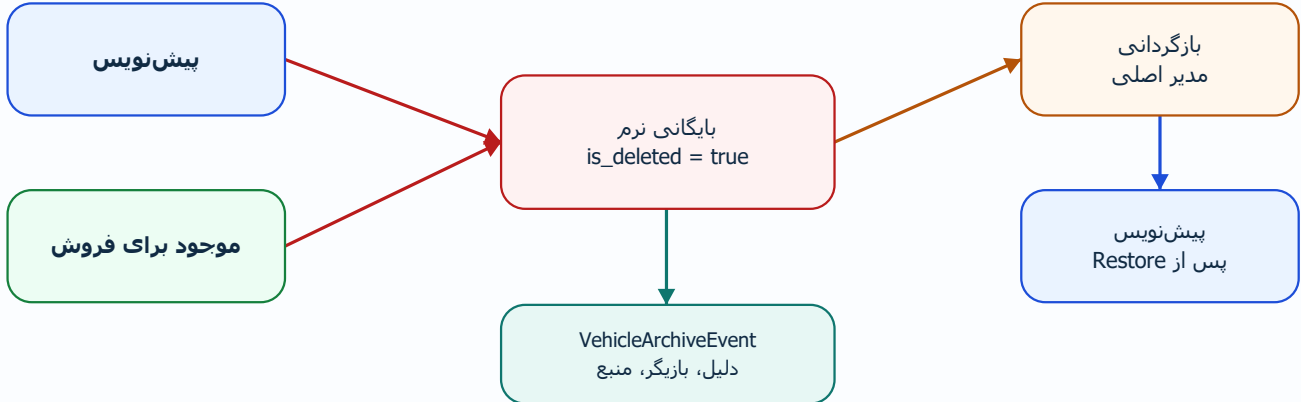
نکته دامنه

محدودیت تخصیص Stage را دور بزنند، اما این bypass در سطح سرویس کنترل شده است؛ نه با ویرایش مستقیم داده در پنل مدیریت. مدیر اصلی می‌تواند

۶. بایگانی نرم خودرو و چرخه بازگردانی

قابلیت Archive جایگزین حذف فیزیکی خودرو در مسیرهای معمول سیستم شده است.

نمودار ۵ - چرخه بایگانی و بازگردانی خودرو



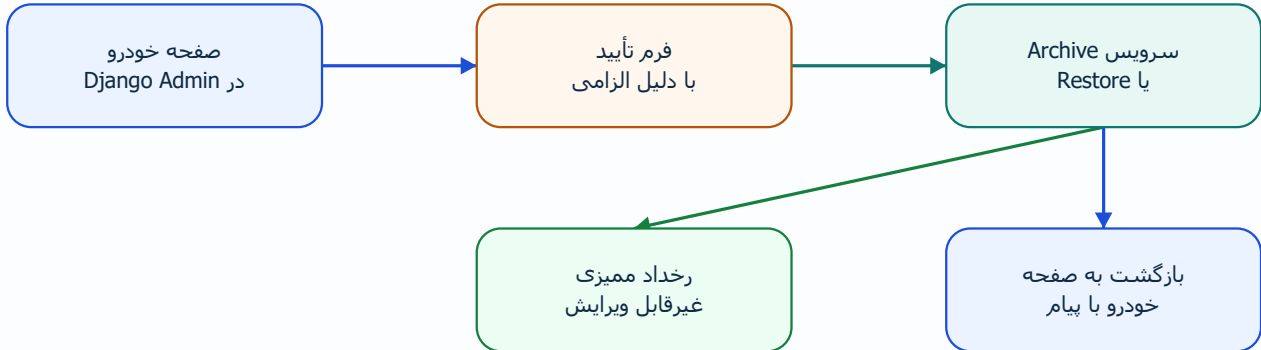
خودروی Restore شده همیشه Draft است و برای نمایش عمومی باید دوباره Publish شود.

وضعیت خودرو	بایگانی امکان	علت تصمیم
Draft	بله	منتشر نشده می تواند از موجودی کنار گذاشته شود خودروی
For Sale	بله	از فروش عمومی خارج می شود ولی داده حذف نمی شود خودرو
On Hold	خیر	ابتدا باید رزرو آگاهانه آزاد شود
Sold	خیر	اطلاعات مشتری و رهگیری باید حفظ شود
In Transit / Delivered	خیر	رهگیری حمل نباید مخفی یا حذف شود

۷. امنیت Django Admin

مسیر اجرایی است، نه محل تغییر مستقیم چرخه عمر خودرو Admin

نمودار ۶ - جریان امن عملیات در پنل مدیریت



عملیات حذف دائمی در Admin غیرفعال شده و مسیر عادی تنها از فرم و سرویس ممیزی شده می‌گذرد.

موضوع	کنترل Admin	نتیجه
حذف خودرو	CarAdmin.has_delete_permission = False	واقعی از تمام مسیرهای عادی Admin بسته است حذف
بایگانی	URL اختصاصی Archive	کارمند مجاز فرم دلیل‌دار می‌بیند
بازگردانی	URL اختصاصی Restore	فقط مدیر اصلی فرم Restore را می‌بیند
فیلدهای چرخه عمر	readonly_fields	status, tracking code, is_deleted ممکن نیست تغییر مستقیم customer
ممیزی	VehicleArchiveEventAdmin و Inline	رخدادها فقط‌خواندنی و فقط برای مدیر اصلی هستند

و سپس Service Layer مجوز و وضعیت خودرو را دوباره بررسی می‌کنند. پنهان کردن دکمه صرفاً برای تجربه کاربری است، نه مرز امنیتی. حتی اگر شخصی URL اختصاصی را به‌صورت مستقیم باز کند، خود View

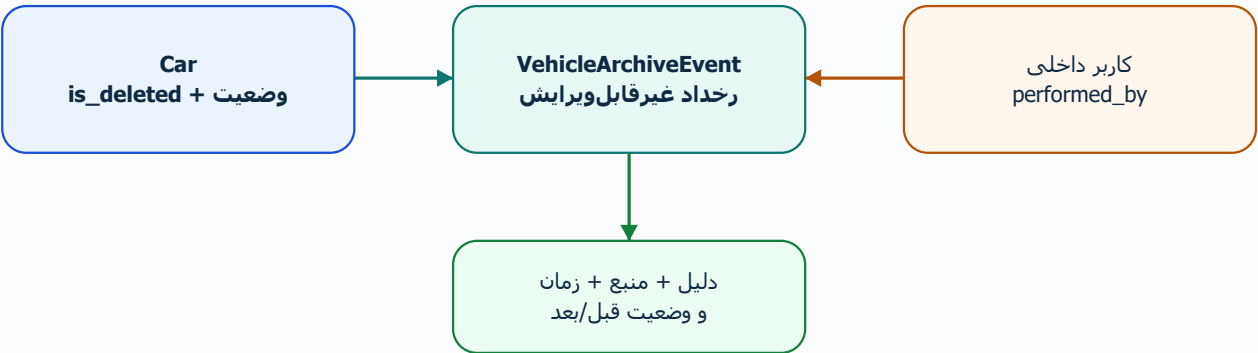
قاعده Restore

- فقط System Administrator می‌تواند Restore انجام دهد.
- می‌رود Draft همیشه به status تغییر می‌کند، اما False به is_deleted.
- برای بازگشت به فروش عمومی باید Publish جداگانه اجرا شود.

۸. ردپای ممیزی، تراکنش و همزمانی

رویدادهای مهم باید قابل بازسازی باشند و تغییر همزمان کارکنان نباید داده ناسازگار تولید کند.

نمودار ۷ - ساختار ردپای ممیزی بایگانی



مجدد، زنجیره ممیزی را در مسیرهای عادی حفظ می‌کنند save/delete های محافظت‌شده و منع ForeignKey

VehicleArchiveEvent

فیلد	کاربرد	داده ثبت‌شده
car / performed_by	شخصی بر کدام خودرو عمل کرده است مشخص می‌کند چه	خودرو و بازیگر
action	نوع دقیق رویداد	archive یا restore
previous_status / new_status	توضیح تصمیم Draft به Restore	وضعیت پیش و پس از عمل
source	از Admin، وبسایت و Telegram آینده پشتیبانی	رابط انجام عملیات
reason / created_at	پاسخ‌گویی و گزارش مدیریتی	دلیل و زمان

۹. آزمون و صحت‌سنجی نهایی

اجرای نهایی در Docker Compose انجام شده است.

نمونه پوشش	مازول	تعداد
ساخت گروه‌ها، مجوز و محدودیت کارمند ترخیص	accounts	۹
چرخه فروش، Archive/Restore، فرم Admin و منع حذف دائمی	cars	۳۳
درخواست سفارشی، تبدیل به فروش و دسترسی‌ها	customers	۱۴
تاریخچه، اصلاح/پرش و رهگیری عمومی، Stage	tracking	۲۸
اجرای کامل با نتیجه OK	جمع	۸۴

فرمان‌های اجراشده

```
docker compose exec -T web python manage.py makemigrations --check --dry-run
```

```
docker compose exec -T web python manage.py sync_roles
```

```
docker compose exec -T web python manage.py test
```

موفق Employee و Clearance Employee، و اجرای ۸۴ تست بدون خطا. همچنین Django system check هیچ مسئله‌ای گزارش نکرد. خروجی نهایی: No changes detected، همگام‌سازی

همزمانی و دوام داده

- سرویس‌های حساس با transaction.atomic اجرا می‌شوند؛ شکست در میانه فرآیند، تغییرات نیمه‌کاره را rollback می‌کند.
- جلوگیری می‌کند Stage از رقابت همزمان بین رزرو، فروش، بایگانی و تغییر select_for_update.
- غیرقابل ویرایش و حذف هستند model save/delete از مسیر TrackingEvent و VehicleArchiveEvent.
- محدودیت دیتابیس برای هر خودرو فقط یک VehicleHold فعال اجازه می‌دهد.

۱۰. راهنمای عملیاتی مدیر سیستم

پس از Deploy یا تغییر Migration، این ترتیب اجرا شود.

راه اندازی نقش‌های پایه

```
docker compose exec -T web python manage.py migrate
docker compose exec -T web python manage.py sync_roles
```

1. کاربران داخلی را با is_staff فعال ایجاد یا فعال کنید.
2. کاربران معمولی را به گروه Employee یا Clearance Employee اضافه کنید.
3. برای عملیات استثنایی مانند فروش یا آزادسازی رزرو، Permission صریح بدهید؛ گروه پایه را بیش از حد گسترده نکنید.
4. برای هر کارمند ترخیص، Stageهای مجاز را در StaffProfile تخصیص دهید.
5. برای حذف عملیاتی خودرو، از گزینه Archive در صفحه خودرو استفاده کنید و دلیل روشن ثبت کنید.
6. Publish فقط توسط مدیر اصلی انجام شود؛ سپس در صورت نیاز خودرو را جداگانه Restore کنید.

قاعده توسعه آینده

را مستقیم تغییر دهد. نقطه ورود باید یک Service Layer مشخص باشد و همان سرویس مجوز، تراکنش، lock و event را مدیریت کند. هیچ Task، Bot Handler، View یا Command جدید نباید فیلدهای current_stage، is_deleted، status یا رخدادها را ممیزی

۱۱. پیاده‌سازی‌شده در برابر برنامه آینده

شفافیت دامنه از ادعای قابلیت‌های پیاده‌سازی‌نشده مهم‌تر است.

موضوع	قابلیت	وضعیت
RBAC	پایه، Stage assignment و سرویس‌های مشترک نقش‌ها، Permission‌های	پیاده‌سازی شده
Tracking	رهگیری عمومی، تاریخچه Stage و کنترل Staff	پیاده‌سازی شده
فروش	رزرو موقت، فروش دستی و کد رهگیری	پیاده‌سازی شده
موجودی	امن Admin ممیزی‌شده و پنل Archive/Restore	پیاده‌سازی شده
Telegram	پیام مشتری و همگام‌سازی کانال، Bot‌های Handler	برنامه‌ریزی‌شده
Bulk Import	و گزارش خطا Worker، Job، Excel upload	برنامه‌ریزی‌شده
رابط کاربری	صفحات موجودی، RTL، AdminLTE و طراحی بصری نهایی	برنامه‌ریزی‌شده
عملیات	monitoring ساخت‌یافته و Outbox، retry، logging	برنامه‌ریزی‌شده

۱۲. نتیجه و Commit پیشنهادی

فاز ۶ اکنون یک مرز امنیتی قابل اتکا میان رابطها و منطق کسب‌وکار فراهم می‌کند.

بدون تکرار منطق وارد شوند، قاعده اصلی این است: رابطها قابل تعویض‌اند، اما Service Layer منبع واحد حقیقت باقی می‌ماند. معماری فعلی آماده است تا در فازهای بعد، Excel Import، Website، Telegram Bot، و Notification‌ها

ریسک‌های باقی‌مانده

موجودی خودرو هنوز پیاده‌سازی نشده است؛ در زمان ساخت باید همیشه `is_deleted=False` و `status=FOR_SALE` فیلتر شود.

- وبسایت

طراحی شود `retry` و `Outbox` هنوز به سیستم وصل نیست؛ برای همگام‌سازی قابل اعتماد باید Telegram

SQL خارج از قرارداد برنامه همچنان ممکن است؛ استاندارد تیم باید ممنوعیت `delete` خودرو و استفاده اجباری از `archive_vehicle` باشد.

- حذف مستقیم با ORM یا

پیشنهادی Commit

feat(phase-6): enforce RBAC and audit-safe vehicle lifecycle controls

توضیح پیشنهادی Commit

- centralize staff, permission, and stage-assignment guards
- synchronize Employee and Clearance Employee baseline roles
- protect vehicle, sale, request conversion, and tracking workflows
- harden Django Admin against direct lifecycle mutations
- add audited soft archive/restore controls for inventory vehicles
- add archive/admin regression coverage

پایان گزارش

وضعیت: فاز ۶ تکمیل، Migration سازگار، Role‌ها همگام و ۸۴ تست سبز.